MF0488_3 –GESTIÓN DE INCIDENTES DE SEGURIDAD INFORMÁTICA

1. Sistemas de Detección y Prevención de Intrusiones (IDS/IPS)
2. Implantación y Puesta en Producción de Sistemas IDS/IPS
3. Control de Código Malicioso
4. Respuesta ante Incidentes de Seguridad
5. Proceso de Notificación y Gestión de Intentos de Intrusión
6. Análisis Forense Informático

Módulo 2 Implantación y Puesta en Producción de Sistemas IDS/IPS

Objetivos:

Analizar los procedimientos técnicos y operativos necesarios para la implantación eficaz de sistemas IDS/IPS, desde el estudio del entorno organizativo hasta la configuración, validación, supervisión y mantenimiento continuo, garantizando la protección adaptada frente a intrusiones.

Contenido:

1. Análisis previo de los servicios, protocolos, zonas y equipos que utiliza la organización para sus procesos de negocio
2. Definición de políticas de corte de intentos de intrusión en los IDS/IPS
3. Análisis de los eventos registrados por el IDS/IPS para determinar falsos positivos y caracterizarlos en las políticas de corte del IDS/IPS
4. Relación de los registros de auditoría del IDS/IPS necesarios para monitorizar y supervisar su correcto funcionamiento y los eventos de intentos de intrusión
5. Establecimiento de los niveles requeridos de actualización, monitorización y pruebas del IDS/IPS

1. Análisis previo de los servicios, protocolos, zonas y equipos que utiliza la organización para sus procesos de negocio

1.1. Identificación de los Servicios y Procesos críticos de la organización

Importancia del análisis previo en la implantación de IDS/IPS

Antes de desplegar cualquier Sistema de Detección o Prevención de Intrusiones, es imprescindible llevar a cabo un análisis exhaustivo del entorno tecnológico y operativo de la organización.

Este análisis permite identificar qué servicios, procesos, protocolos y dispositivos deben ser protegidos de forma prioritaria, y en qué puntos resulta más eficaz y viable implementar soluciones IDS/IPS

No todas las áreas de la red ni todos los servicios tienen el mismo nivel de exposición o impacto sobre la continuidad del negocio. El despliegue debe alinearse con los objetivos organizativos y las necesidades reales de seguridad, evitando tanto zonas desprotegidas como sobreprotección innecesaria.

Clasificación de Servicios según su criticidad

- **Impacto en la continuidad del negocio**: Un Servicio crítico es aquel cuya interrupción produce consecuencias operativas o económicas graves
- **Sensibilidad de los datos procesados**: Servicios que manejas datos personas, financieros, sanitarios o estratégicos que deben considerarse prioritarios a nivel de seguridad. También pueden estar sujetos a obligaciones legales o contractuales.
- **Nivel de exposición externa**: Los servicios accesibles desde Internet están más expuestos a ataques, por lo que deben contar con mecanismos de detección reforzados.
- **Dependencia tecnológica de otros procesos**: Algunos servicios, aunque no sean críticos por sí solos, soportan otros que sí lo son.

Priorización y mapeo de procesos

Una vez identificados los servicios y aplicaciones, es fundamental mapear los procesos de negocio de dependen de ellos. Este mapeo permite alinear la seguridad con las necesidades funcionales y operativas de la organización, y diseña una arquitectura IDS/IPS que proteja lo verdaderamente importante.

Recomendaciones:

- Elaborar un catálogo de procesos clave: producción, atención a clientes, facturación, operaciones, …
- Asociar a cada proceso los servicios tecnológicos que lo soportan
- Identificar los activos técnicos implicados
- Determinar los horarios críticos, el personal implicado y las posibles rutas de acceso a los datos.

Elemento analizado	Descripción	Función dentro del análisis previo
Servicio crítico	Proceso o sistema cuya interrupción afecta gravemente a la organización	Prioriza su protección y supervisión
Datos sensibles	Información personal, confidencial o estratégica	Requiere protección reforzada según normativa
Nivel de exposición	Grado de accesibilidad externa o interna	Aumenta la prioridad de detección en servicios expuestos
Dependencia de tecnología	Relación entre servicios que comparten infraestructura	Implica ampliar la cobertura IDS/IPS a servicios de soporte
Mapeo de procesos	Relación entre servicios, procesos y activos técnicos	Permite diseñar una arquitectura de detección eficaz

1.2. Análisis de protocolos, zonas de red y dispositivos involucrados en los servicios identificados

Evaluación de Protocolos utilizados

Una vez identificados los servicios críticos de la organización, el siguiente paso es analizar los protocolos de red empleados por dichos servicios, con el fin de determinar sus implicaciones de seguridad y relevancia para el despliegue de IDS/IPS.

Este análisis resulta clave para afinar los mecanismos de inspección y establecer reglas adecuadas de detección o prevención.

Protocolos utilizados:

- **Tipos y función del protocolo**
  - Protocolos de transporte (TCP, UDP, ICMP): permiten la comunicación básica entre dispositivos
  - Protocolo de aplicación (HTTP, HTTPS, FTP, DNS, SMTP, IMPA, LDAP): soportan los servicios concretos del negocio
  - Protocolos propietarios o específicos de sistemas industriales (Modbus, OPC-UCA, BACnet)
- **Grado de exposición o riesgo**: Algunos protocolos son más susceptibles de explotación por software malicioso.
  - FTP: Transmite datos en texto claro, por lo que es fácilmente interceptable
  - RDP: Puede ser atacado mediante fuerza bruta si no está adecuadamente protegido
  - DNS: Puede ser utilizado para canalizar malware o realizar tunneling.
- **Compatibilidad con Sistemas de Inspección**: Algunos protocolos cifrados pueden dificultar el análisis si no se emplean mecanismos de inspección profunda (Deep Packet Inspection)

Delimitación de zonas de red y segmentos funcionales

El análisis previo a la implantación de un Sistema IDS/IPS debe incluir la delimitación clara de las zonas de red de la organización. Esta división permite diseñar una arquitectura de sensores distribuida, segmentar los niveles de riesgo y definir políticas adaptadas a cada contexto.

Zonas típicas que deben identificarse:

- **Zona perimetral:** Incluye todos los dispositivos expuestos a redes externas (routers, cortafuegos, proxies, servidores en la DMZ). Es el punto más vulnerable y donde resulta imprescindible instalar sensores NIDS/NIPS
- **Zona interna de usuarios:** Agrupa los equipos del personal: estaciones de trabajo, portátiles, dispositivos móviles,.. Aunque está menos expuesta, puede convertirse en origen de amenazas externas.
- **Zona de servidores:** Incluye servidores de aplicaciones, Bases de datos, autenticación, correo, almacenamiento, … Su protección requiere una combinación de sensores de red e IDS basados en host
- **Zona administrativa o de gestión:** Engloba consolas de administración, sistemas de monitorización, interfaces de red de administración remota. Debe estar especialmente segmentada y protegida por los permisos de los que dispone.
- **Zona de laboratorio, pruebas o invitadas:** Segmentos de red usados para pruebas, entornos de desarrollo o acceso de visitantes. Deben estar totalmente aislados del resto de la red de producción y contar con sensores de inspección independientes.

Identificación de Dispositivos Clave

Además de analizar protocolos y zonas, es fundamental identificar los dispositivos críticos que intervienen en los procesos de negocio. Esta identificación permite saber qué activos deben estar prot3egidos mediante mecanismos IDS/IPS, y qué tipo de sensor o regla aplicar en cada caso.

Dispositivos a identificar:

- **Dispositivos de red:** Switches, routers, balanceadores, puntos de acceso inalámbricos. En muchos casos no se protege directamente el dispositivo, sino el tráfico que gestionan.
- **Servidores:** Sistemas que alojan servicios de negocio: web, BD, DNS, correo, ficheros. Deben proteger con sensores HIDS, reglas personalizas, y en ocasiones IPS para bloquear ataques conocidos.
- **Estaciones de trabajo críticas:** Puestos administrativos, TPV, o de personal técnico con permiso de administrador. En algunos entornos es aconsejable instalar agentes IDS locales.
- **Dispositivos IoT o industriales:** Cámaras, sensores, SCADA, autómatas, sistemas embebidos. Requieren soluciones IDS específicas, capaces de interpretar sus protocolos.
- **Equipos móviles o remotos:** Portátiles con acceso VPN, dispositivos del personal, terminales de acceso remoto,... Deben supervisarse desde los puntos de entrada y aplicarse controles de acceso reforzados.

¿Qué es un sistema SCADA, para qué sirve y cómo funciona?

2. Definición de políticas de corte de intentos de intrusión en los IDS/IPS

2.1. Criterios técnicos para la definición de políticas de corte

Fundamentos de las Políticas de corte en los Sistemas IDS/IPS

Las **políticas de corte** son el conjunto de reglas, condiciones y acciones configuradas en un sistema IDS/IPS que determinan qué hacer ante un intento de intrusión detectado.

En los Sistemas IPS, estas políticas permiten bloquear o mitigar automáticamente ciertos tipos de tráfico sospechoso o malicioso.

En los Sistemas IDS, pueden utilizarse para generar alertas específicas, aislar eventos y activar protocolos de escalado.

Fundamentos de las Políticas de corte en los Sistemas IDS/IPS

La definición de estas políticas debe basarse en un enfoque técnico riguroso que contemple tanto la precisión en la detección como la minimización de falsos positivos y negativos. Deben proteger eficazmente sin interferir indebidamente en la operativa normal de la organización.

Principios técnicos para definir políticas efectivas:

- **Especialidad y granularidad:** Las reglas deben de ser lo más específicas posibles. En lugar de bloquear todo el tráfico desde una IP, podemos bloquear un protocolo, un rango horario, o un recurso concreto.
- **Basado en análisis de riesgos**: La configuración debe orientarse a proteger los activos más críticos y los ataques más probables.
- **Minimización del impacto operacional**: Debe evitarse cortar servicios de los que dependan los activos esenciales.
- **Ajuste dinámico y aceptable**: Las políticas deben evolucionar con el tiempo, en función de la experiencia acumulada, los incidentes producidos y las nuevas amenazas emergentes, por lo que el sistema debe disponer de mecanismos de actualización y aprendizaje.
- **Trazabilidad y reversibilidad**: Los cortes deben quedar registrados, ser reversibles y permitir un análisis forense posterior.

Parámetros técnicos configurables en una política de corte:

- **Umbrales cuantitativos**
  - Número de intentos de conexiones fallidos
  - Volumen de tráfico anómalo
  - Número de evento similares en un período de tiempo
- **Condiciones contextuales:** Hora del día, día de la semana, Localización geográfica IP de origen, Usuario o rol implicado
- **Acciones asociadas:**
  - Generar alerta
  - Bloquear IP, puerto o protocolo
  - Cortar sesión activa
  - Activar reglas adicionales
- **Nivel de criticidad:** Cada política debe tener un nivel asociado (bajo, medio, alto o crítico), lo que influye en la priorización, la visibilidad o el protocolo escalado.

2.2. Política progresiva, validación y revisión de las políticas de corte

Implantación progresiva de políticas de corte

La aplicación de políticas de corte en sistemas IDS/IPS no debe realizarse de una forma inmediata ni masiva, ya que esto puede generar interrupciones no deseadas, bloqueos o falsos positivos que afecten a la operativa, por lo que se recomienda una implantación progresiva, basada en fases y pruebas controladas, que permiten ajustar y validar el comportamiento del sistema antes de activar respuestas automáticas.

Fases de aplicación progresiva

- **Fase de monitoreo pasivo:** Inicialmente, las reglas se configuran en modo observación, sin aplicar acciones de corte. Esto permite recoger información sobre su impacto potencial y calibrar los umbrales sin riesgo operativo
- **Activación parcial con acciones limitadas:** Las reglas se aplican a segmentos de red concretos, horarios restringidos o servicios no críticos. Se configuran acciones no destructivas como la generación de alertas, redirecciones o bloqueos temporales
- **Despliegue completo y escalado progresivo:** Una vez validado su comportamiento, las políticas se activan en todos los entornos previstos. Se establecen niveles de criticidad diferenciados y se automatizan las respuestas según los resultados obtenidos.
- **Documentación y trazabilidad del proceso:** Toda modificación debe estar debidamente documentada, incluyendo fecha de activación, personal responsable, parámetros modificados y resultados esperados.

Validación técnica de las políticas implementadas

Una vez activadas, las políticas de corte deben ser validadas técnica y operativamente para asegurar que cumplen con sus objetivos sin producir efectos secundarios no deseados.

Esta validación se basa en la observación métrica y resultados reales, así como simulaciones y análisis retrospectivos.

Revisión periódica y mejora continua

Las políticas de corte no deben considerarse definitivas, sino que requieren un proceso cíclico de revisión, actualización y mejora continua, especialmente en entornos cambiantes o con alta exposición a amenazas.

Mecanismos claves para la revisión:

- Revisión programada (mensual, trimestral, anual,…)
- Incorporación de inteligencia de amenazas (threat intelligence)
- Adaptación a cambios internos
- Auditoría y documentación

Métodos habituales de validación:

- **Análisis de falsos positivos y negativos:** Se revisan los eventos generados por el IDS/IPS para determinar si las alertas y bloqueos fueron justificados. Los falsos positivos deben minimizarse, mientras que los falsos negativos deben detectarse y corregirse.
- **Simulación de ataques controlados (penetration testing):** Permite verificar si las reglas responden ante amenazas concretas. Se utilizan herramientas como Metasploit, Nmap, Nkito o scripts propios.
- **Análisis de métricas clave:** Tiempo medio de respuesta ante una amenaza, número de eventos bloqueados por política, tasa de alertas legítimas frente a falsas, impacto sobre el tráfico total,..
- **Recogida de feedback del equipo de seguridad:** El personal técnico debe informar de dificultades, inconsistencias, excesiva carga de trabajo, o lagunas en la detección, de forma que las políticas se ajusten a la realidad operativa.

https://www.metasploit.com/
Metasploit Framework: Explotar vulnerabilidades puede ser bastante fácil

3. Análisis de los eventos registrados por el IDS/IPS para determinar falsos positivos y caracterizarlos en las políticas de corte del IDS/IPS

3.1. Métodos de Identificación de falsos positivos

Definición y relevancia de los falsos positivos

Un falso positivo en Seguridad Informática se produce cuando el sistema IDS/IPS detecta como amenaza una actividad legítima, generando una alerta o una acción de corte no justificada.

Este tipo de errores pueden:

- Distraer la atención el equipo de seguridad
- Generar una sobrecarga de alertas
- Provocar interrupciones de servicios legítimos
- Disminuir la confianza en el sistema de detección

Estos sistemas trabajan con reglas definidas por patrones o anomalías, por lo que es inevitable cierto margen de error. La clave está en identificar y clasificar los falsos positivos con rapidez, para afinar las políticas de detección y mantener un equilibrio adecuado entre seguridad y operatividad.

Tipología de los falsos positivos más comunes

- Actividades legítimas con patrones similares a los de un ataque: Un escaneo de red autorizado puede confundirse con un ataque de reconocimiento.
- Configuración excesivamente restrictiva de reglas: Prohibir la ejecución de cualquier programa no autorizado expresamente.
- Falta de contexto en la detección (no correlación de eventos): Un evento aislado puede activar una alarma, pero al analizar varios eventos en su conjunto considerarse inofensivo.
- Errores de clasificación por parte del Sistema

Técnicas de Identificación y Análisis

Para identificar falsos positivos de manera sistemática, es necesario aplicar técnicas de revisión y análisis de eventos que combinen observación manual, herramientas automatizadas y validación cruzada.

- Revisión del log completo del evento
- Comparación con registros externos
- Consulta al equipo implicado o usuario final
- Uso de listas de excepciones o whitelists
- Análisis de comportamiento a largo plazo

3.2. Inclusión de excepciones y reconfiguración de reglas a partir del análisis de falsos positivos

Ciclo de Gestión de Falsos Positivos:

1. **Identificar eventos legítimos**: reconocer y verificar eventos legítimos
2. **Aplicar excepciones**: Crear reglas whitelists para eventos legítimos
3. **Ajustar umbrales**: Modificar umbrales y condiciones contextuales
4. **Actualizar reglas**: Eliminar o actualizar reglas obsoletas
5. **Crear reglas personalizadas**: Desarrollar reglas adaptadas al entorno
6. **Registrar cambios**: Documentar y revisar todos los cambios



Excepciones

Tras identificar un evento como falso positivo, es necesario decidir si debe excluirse de futuras detecciones para evitar alertas innecesarias. Esta exclusión se realizar mediante la inclusión de excepciones o listas blancas (whitelists), que permiten afinar la precisión del sistema IDS/IPS sin comprometer su capacidad de detección.

Reconfiguración de Reglas y Ajustes técnicos

La Gestión de eficaz de los falsos positivos requiere ajustar las reglas de detección para que sean más precisas, contextuales y adaptativas.

Esta reconfiguración permite mejorar el comportamiento global del IDS/IPS y reducir la sobrecarga del equipo de análisis.

Ajustes técnicos:

- Modificación de umbrales
- Refinamiento de condiciones contextuales
- Actualización de reglas heredadas u obsoletas
- Creación de reglas personalizadas

4. Relación de los registros de auditoría del IDS/IPS necesarios para monitorizar y supervisar su correcto funcionamiento y los eventos de intentos de intrusión

4.1. Tipología y estructura de los registros de auditoría generados por Sistemas IDS/IPS

Los Registros de Auditoría en IDS/IPS combinan datos técnicos y contextuales para documentar eventos, acciones y configuraciones, siendo fundamentales en la seguridad proactiva, el cumplimiento legal y la respuesta ante incidentes.

Finalidad de los registros de auditoría

Los Registros de auditoría en IDS/IPS constituyen una fuente crítica de información para el control y la supervisión de la seguridad en una organización.

Estos registros permiten:

- Verificar el correcto funcionamiento del Sistema de detección y prevención
- Analizar eventos sospechosos o incidentes reales con fines forenses
- Detectar errores de configuración, fallos o interrupciones del Sistema
- Cumplir con requisitos legales y normativos, como el ENS, RGPD, o NIS-2.

*A diferencia de los logs operacionales o de sistema, los registros de auditoría de seguridad tienen valor probatorio, por lo que deben cumplir ciertos requisitos de integridad, trazabilidad y conservación.

Tipos de registros de auditoría en sistemas IDS/IPS

Los Sistemas IDS/IPS generan diferentes tipos de registros, que pueden clasificarse según su finalidad o el tipo de evento documentado.

Los más relevantes son:

- Registros de eventos de seguridad (alertas): incluyen información detallada sobre cualquier detección realizada por el sistema: tipo de amenaza, fecha y hora, dirección IP de origen y destino, protocolo, puerto, regla activada, acción realizada
- Registros de acciones automatizadas: documentan las respuestas automáticas que ha ejercido el sistema en función de sus políticas de corte: bloqueos de IP, interrupción de sesiones, aplicación de reglas temporales,…
- Registros de administración y configuración: reflejan cambios realizados en la configuración del IDS/IPS, como modificación de reglas, inclusión de excepciones, actualización de firmas, ajustes de umbrales o activación de políticas
- Registros de acceso al Sistema: recogen las sesiones iniciadas por usuarios administradores, los cambios ejecutados desde la consola de gestión, el acceso a las BD internas, entre otros. Son clave para auditar la actuación del personal técnico.
- Registro de funcionamiento y errores del Sistema: informan del estado interno del IDS/IPS

Estructura técnica de un Registro de Auditoría

Para que un registro de auditoría sea útil, debe estar correctamente estructurado, siguiendo un formato normalizado que permite su lectura, análisis automático y conservación.

Los campos más comunes son:

- Encabezado del evento: identificador único del evento, fecha y hora exacta, así como clasificación del evento (informativo, advertencia, crítico)
- Datos técnicos del incidente: IP de origen y destino, puerto y protocolo implicado, tipo de ataque o anomalía detectada, nivel de severidad asignado, regla o política que disparó el evento.
- Acción asociada: acción tomada automáticamente por el Sistema (alerta, bloqueo, redirección), usuario o proceso que ejecutó el cambio, así como código de retorno, si procede.
- Metadatos de contexto: segmento de red, zona funcional o ubicación lógica del sensor, dispositivo implicado, y aplicación o servicio asociado al tráfico.
- Firma digital o hash (opcional): garantiza la integridad del registro para su uso en auditoría forense

Tipo de registro de auditoría	Finalidad principal	Campos clave incluidos
Eventos de seguridad	Documentar detecciones realizadas por el IDS/IPS	Fecha, IP origen/destino, tipo de ataque, regla activada
Acciones automáticas	Registrar bloqueos, cierres o redirecciones ejecutadas por el sistema	Acción tomada, duración, IP afectada
Administración y configuración	Auditar cambios realizar por el personal técnico	Usuario, tipo de cambio, hora, valores anteriores y nuevos
Accesos al sistema	Controlar quién entra en el sistema y qué acciones realiza	Usuario, hora de acceso, cambios realizados
Estado del sistema	Detectar fallos internos el IDS/IPS o errores operativos	Código de error, servicio afectado, duración del fallo

4.2. Técnicas de supervisión, almacenamiento y consulta de registros de auditoría

Gestionar registros de auditoría implica supervisión activa, almacenamiento seguro y análisis avanzado para garantizar integridad, cumplimiento y respuesta ante incidentes.

Supervisión activa de registros de auditoría

La mera existencia de registros de auditoría no garantiza por sí sola un entorno seguro.

Es necesario aplicar una supervisión activa, mediante herramientas, procedimiento y personal especializado, que permita:

- Detectar eventos críticos en tiempo real
- Correlacionar registros con otros Sistemas
- Generar alertas automáticas ante patrones sospechosos
- Identificar anomalías que podrían pasar desapercibidas

Las técnicas de supervisión más eficaces combinan automatización, visualización y análisis técnico.

Técnicas de supervisión:

- Integración con plataformas SIEM: los SIEM (Security Information and Event Management) permiten centralizar los registros generados por múltiples dispositivos. Mediante reglas de correlación, dashboards y motores de búsqueda, el SIEM convierte los registros en información útil y operativa.
- Sistemas de alerta y notificación: Los eventos críticos pueden generar alertas automáticas, ya sea por correo electrónico, mensajería, o integración con plataformas SOAR. Estas alertas deben tener umbrales definidos y asociarse a protocolos de actuación.
- Paneles de visualización (dashboards): Las consolas de IDS/IPS y los SIEM ofrecen interfaces gráficas donde se representan en tiempo real los eventos más relevantes, su distribución temporal, geográfica, o por tipo de amenaza. Esto permite una respuesta más ágil por parte del equipo de seguridad.
- Supervisión continua o por turnos (SOC): En entornos con alta criticidad o gran volumen de registros, la supervisión se delega a un Centro de Operaciones de Seguridad (SOC), con personal disponible 24x7 o con monitorización semiautomatizada.

¿Qué es SIEM?

SIEM: Security Information & Event Management

Almacenamiento seguro y conforme a la normativa

El almacenamiento de registros de auditoría debe cumplir no solo requisitos técnicos de integridad y disponibilidad, sino también exigencias legales y normativas, ya que pueden contener datos sensibles o tener valor probatorio.

- Formato normalizado: Se recomienda que los registros se almacenen en formatos estructurados (json, xml csv) y normalizados que faciliten su análisis, exportación y lectura automática.
- Integridad y No repudio: Los registros deben protegerse frente a modificaciones o eliminaciones. Esto puede lograrse mediante firmas digitales, sistemas WORM, o sellado temporal
- Redundancia y alta disponibilidad: Los Sistemas deben contar con copias de seguridad automáticas, replicación geográfica o almacenamiento distribuido para garantizar la recuperación ante fallos.
- Retención temporal y borrado seguro: La normativa legal (ENS. RGPD, ISO 27000) suele exigir retención mínima durante un tiempo determinado (6 meses, 1 año, ...) y eliminación segura tras ese plazo. Debe poder demostrarse que el registro no ha sido alterado durante su ciclo de vida.

Búsqueda y análisis de registros

Una vez almacenados, los registros deben ser **accesibles y analizables** para extraer valor en tiempo real y en auditorías posteriores. La capacidad de búsqueda y análisis eficiente es clave para la gestión de incidentes y la mejora continua.

- Indexación y búsqueda avanzada: Mediante herramientas como Elasticsearch o motores de los SIEM, se pueden realizar búsquedas complejas combinando campos (IP, tipo de evento, período temporal, severidad,…). Este agilizará el análisis forense y la investigación de incidentes
- Correlación entre múltiples fuentes: Al analizar un registro concreto, es fundamental poder relacionarlo con otros eventos previos o simultáneos, lo que ofrece una visión completa del incidente
- Exportación para auditoría o peritaje: Los registros deben poder exportase en formatos seguros y compatibles con herramientas externas, garantizando la validez jurídica de los datos en caso de ser necesario.
- Uso de IA o ML: Algunos sistemas aplican técnicas de análisis predictivo sobre los registros para identificar patrones de ataque, clasificar registros o anticipar amenazas emergentes.

Procedimientos legales ante un ciberataque: pasos a seguir según la ley española

5. Establecimiento de los niveles requeridos de actualización, monitorización y pruebas del IDS/IPS

5.1. Planificación de actualizaciones y mantenimiento del Sistema IDS/IPS

La **Actualización y el Mantenimiento planificados** de los Sistemas IDS/IPS son esenciales para garantizar su eficacia frente a amenazas cambiantes y mantener la seguridad operativa de la organización.

Actualización continua como eje de eficacia

Los Sistemas IDS/IPS, por su propia naturaleza, dependen de una actualización constante para mantener su eficacia. Las amenazas evolucionan con rapidez, y un sistema que no actualiza sus reglas, firmas o mecanismos de análisis puede volverse ineficaz en cuestión de semanas.

Las actualizaciones se aplican sobre diferentes componentes del Sistema:

- Base de datos de firmas o patrones: Su activación permite detectar amenazas emergentes o campañas activas
- Motor de análisis o detección: Periódicamente se publican mejoras en el algoritmo de detección, y es importante mantener actualizado el motor para aprovechar mejoras de rendimiento o cobertura.
- Sistema Operativo o plataforma base: Los IDS/IPS se ejecutan sobre un sistema base que también debe ser actualizado con parches de seguridad, mejoras de estabilidad y correcciones funcionales.
- Reglas personalizadas y excepciones: Si se han definido políticas propias es necesario revisarlas y actualizarlas periódicamente para adaptarlas a nuevos servicios, cambios internos o lecciones aprendidas tras incidentes.

Estrategias de mantenimiento técnico

Un Sistema IDS/IPS correctamente desplegado requiere tareas de mantenimiento programadas, que deben incluirse en el Plan de Seguridad de la organización.

Las tareas no solo consisten en aplicar actualizaciones, sino también en:

- Revisión del rendimiento y consumo de recursos: Es necesario comprobar que el IDS/IPS no está generando cuellos de botella, que dispone de suficiente capacidad de procesamiento y que los logs no están saturando el almacenamiento.
- Verificación del funcionamiento de reglas y sensores: Si alguna regla no se está ejecutando correctamente, es necesario identificarse y corregirse, principalmente después de algún cambio en el Sistema
- Control del estado de Integridad y Disponibilidad: Las herramientas deben disponer de sistemas de alerta que indiquen fallos de servicio, interrupciones no planificadas, corrupción de archivos o desconexión de agentes.
- Rotación de claves y certificados: Si el Sistema usa autenticación basada en certificados, debe asegurarse la rotación periódica de estos elementos.

Programación de actualizaciones y pruebas controladas

Aplicar actualizaciones sin planificación puede tener consecuencias negativas, por lo que es esencial que la organización defina un procedimiento formal para la gestión de actualizaciones, que incluya pruebas previas y criterios de validación.

Tareas a realizar:

- Calendario de actualizaciones programas
- Pruebas en entornos d laboratorio o preproducción
- Criterios de validación y retroceso (rollback)
- Coordinación con otras áreas técnicas

5.2. Pruebas periódicas y supervisión continua del comportamiento del Sistema IDS/IPS

Justificación de las Pruebas periódicas

Aunque un Sistema IDS/IPS esté correctamente instalado, configurado y actualizado, solo mediante pruebas periódicas puede garantizarse que sigue funcionando conforme a los objetivos establecidos.

Estas pruebas permiten:

- Verificar que las reglas de detección están activas y correctamente implementadas
- Comprobar que los sensores o agentes permanecen operativos
- Identificar posibles lagunas en la cobertura o problemas de rendimiento
- Evaluar la eficacia real del Sistema ante escenarios simulados.

Tipos de Pruebas y Técnica aplicables

Existen diversos tipos de pruebas, cada una con un objetivo específico:

- Pruebas de detección de firmas conocidas: Consiste en generar tráfico que simula un ataque confirma reconocida. Se usan para verificar si el sistema detecta correctamente amenazas documentadas.
- Pruebas de evasión y túneles: Evalúan la capacidad para detectar ataques encubiertos, como paquetes fragmentados, tráfico cifrado sin inspección o uso de tunneling DNS. Estas pruebas ayudan a descubrir limitaciones técnicas del sistema.
- Simulación de ataques reales (penetration testing): Se ejecutan pruebas controladas y autorizadas que reproducen técnicas empleadas por actores maliciosos. Se combinan escaneos de puertos, movimientos laterales, escalas de privilegios y exfiltración de datos.
- Pruebas de resiliencia y rendimiento: Se analiza la respuesta del IDS/IPS ante grandes volúmenes de tráfico, múltiples conexiones simultáneas o DDoS. Es útil para validar la robustez del sistema.
- Verificación de alertas y respuestas automáticas: Se generan eventos intencionados para comprobar que las alertas se generan, escalan y registran adecuadamente, y que las acciones automáticas (bloqueo, cortes, ..) funcionan conforme a lo previsto.

Supervisión continua y métricas de evaluación

Junto a las pruebas puntuales, es imprescindible mantener una supervisión continua del comportamiento del IDS/IPS, basada en la observación sistemática de indicadores clave y el análisis de tendencias.

- Indicadores
  - De Rendimiento y carga (tasa eventos/seg, uso cpu, memoria, almacenamiento, Tiempos de respuesta ante eventos críticos, …)
  - De Eficacia (% alertas válidas, nº falsos positivos y falsos negativos, Tº medio de detección y respuesta ante incidentes)
  - De Cobertura (nº sensores activos y conectados, % tráfico supervisado, nº reglas activas y frecuencia de actuación)
- Informes de actividad periódicos: deben generarse informes semanales, mensuales o trimestrales que recojan los principales resultados del sistema, incidentes detectados, cambios aplicados y áreas de mejora.